

OE-EC803C — Cyber Security

Semester VIII • 3L:0T:0P • 3 Credits

Module 3: Cyber Governance Issues, Crimes & Conflicts

CGEC | B.Tech ECE (2023–27) | *Biraj Sarkar*

Contents

1	Cyber Governance & Internet Architecture	2
2	Email Security, Authentication & Impersonation	2
2.1	Email Protocol Mechanics	2
2.2	Impersonation Attacks and Social Engineering	2
3	Cyber Crime, Privacy Laws & Data Sovereignty	3
3.1	GDPR Data Privacy Principles	3
4	Cyber Conflict, Espionage & State-Sponsored Warfare	4

1. Cyber Governance & Internet Architecture

Cyber Governance encompasses the multi-stakeholder international coordination of root internet infrastructure, domain name assignment, and net neutrality policies.

Definition: ICANN, DNSSEC & Net Neutrality

- **ICANN:** Internet Corporation for Assigned Names and Numbers; manages global IP address space (IPv4/IPv6 via IANA) and DNS root zone servers.
- **DNSSEC (DNS Security Extensions):** Adds digital signatures ('RRSIG', 'DNSKEY') to DNS records, allowing resolvers to cryptographically verify DNS response authenticity and prevent DNS Cache Poisoning.
- **Net Neutrality:** Principle mandating ISPs to treat all web data packets equally, prohibiting traffic throttling, blocking, or paid fast-lane prioritization.

2. Email Security, Authentication & Impersonation

Email is the primary initial access vector for over 90% of enterprise cyber attacks.

Email Authentication Verification Stack (SPF, DKIM, DMARC)



2.1 Email Protocol Mechanics

1. **SPF (Sender Policy Framework):** DNS record listing IP addresses authorized to send mail for a domain.
2. **DKIM (DomainKeys Identified Mail):** Attaches an RSA digital signature to message headers, verified against the sender domain's public DNS key.
3. **DMARC:** Evaluates SPF and DKIM alignment, instructing receiving servers how to enforce policy ('p=none', 'p=quarantine', 'p=reject').

2.2 Impersonation Attacks and Social Engineering

- **Phishing vs Spear Phishing vs Whaling:** Broad credential harvesting emails vs customized targeted emails vs executive-targeted attacks.
- **Business Email Compromise (BEC):** Attackers compromise legitimate executive email accounts to order fraudulent wire transfers.
- **Malvertising:** Injecting malicious scripts into advertising networks to trigger drive-by malware downloads.

3. Cyber Crime, Privacy Laws & Data Sovereignty

3.1 GDPR Data Privacy Principles

The EU General Data Protection Regulation (GDPR) mandates 7 core principles:

1. **Lawfulness, Fairness, and Transparency:** Valid consent required for processing.
2. **Purpose Limitation:** Collecting data strictly for specified legitimate purposes.
3. **Data Minimization:** Collecting only necessary data fields.
4. **Accuracy:** Maintaining up-to-date accurate records.
5. **Storage Limitation:** Deleting data when no longer required (Right to be Forgotten).
6. **Integrity and Confidentiality:** Mandating AES encryption and breach notification within 72 hours.
7. **Accountability:** Demonstrating continuous compliance.

Cyber Crime Category	Modus Operandi	Primary Mitigation Control
Financial Cyber Crime	Banking Trojans, SIM swapping, credit card skimming.	Multi-Factor Authentication (MFA), fraud monitoring.
Identity Theft	Stealing PII to fraudulently open accounts/loans.	Credit monitoring, Data Loss Prevention (DLP).
Cyber Stalking / Harassment	Persistent online tracking, doxxing, digital extortion.	Privacy settings, legal enforcement under IT Act.
Ransomware	Cryptographic file locking demanding Bitcoin ransom.	Immutable offline backups, endpoint EDR agents.

Real-World Case Study: WannaCry Ransomware Pandemic (2017)

1. **Exploit Vector:** Leveraged the NSA 'EternalBlue' exploit (CVE-2017-0144) targeting unpatched Microsoft Windows SMBv1 protocol.
2. **Impact:** Encrypted 200,000+ computers across 150 countries within hours (crippling the UK NHS hospitals and FedEx).
3. **Mitigation:** Stopped when security researcher Marcus Hutchins registered the hardcoded kill-switch domain ('iuqerfsodp9ifjaposdfjhgosurijfaewrwerg.com').

4. Cyber Conflict, Espionage & State-Sponsored Warfare

Definition: Cyber Warfare & Sabotage

- **Cyber Espionage:** Unauthorized covert intrusion into state or corporate networks to steal classified strategic intelligence.
- **Cyber Sabotage:** Deliberate destruction or physical disruption of critical physical assets using malware.
- **Cyber Warfare:** Nation-state cyber operations producing casualties or destruction equivalent to conventional armed attacks.

Historical Case Study: Stuxnet Natanz Centrifuge Sabotage (2010)

1. **Target:** Iran's Natanz nuclear enrichment facility running Siemens S7-300 PLCs.
2. **Vector:** Air-gapped network breached via infected USB drives using 4 Windows Zero-day exploits.
3. **Payload:** Altered PLC rotor frequency speeds, spinning centrifuges out of control to self-destruction while sending fake normal telemetry data to monitoring consoles.

Quick Revision — Module 3

Cyber Governance Issues, Crimes & Conflicts | OE-EC803C

Key Concepts and Metrics at a Glance

Email Verification Triad	SPF (IP validation), DKIM (RSA signature), DMARC (enforcement policy).
DNSSEC Security	Adds cryptographic signatures ('RRSIG') to DNS records to prevent cache poisoning.
WannaCry Malware	Global ransomware spreading via EternalBlue SMBv1 exploit; stopped by kill-switch domain.
Stuxnet Attack	Cyber weapon that destroyed physical Iranian nuclear centrifuges via Siemens PLCs.
GDPR Breach SLA	Mandatory reporting of personal data breaches to regulators within 72 hours.

One-Line Definitions

- **Net Neutrality:** Mandatory equal treatment of all web traffic without ISP throttling or fast lanes.
- **BEC Fraud:** Impersonating executive email accounts to order unauthorized wire transfers.
- **Data Sovereignty:** Laws mandating citizen data generated locally must remain within national borders.
- **Spear Phishing:** Highly customized phishing attack targeting a specific individual.

Frequently Asked / Viva Questions

Q1. Define Net Neutrality and state its core rules.

Mandates that ISPs treat all internet traffic equally, prohibiting traffic blocking, throttling, or paid prioritization.

Q2. Explain the function of SPF in email security.

SPF uses a DNS TXT record listing IP addresses authorized to send emails for a domain, preventing header spoofing.

Q3. How does DKIM authenticate outgoing emails?

DKIM attaches a cryptographic digital signature to the email header; receiving mail servers verify it using the sender's public DNS key.

Q4. What is DMARC and what policy actions does it mandate?

DMARC checks SPF and DKIM alignment, instructing receiving servers to enforce 'none', 'quarantine', or 'reject' policies on invalid emails.

Frequently Asked / Viva Questions (contd.)**Q5. Describe the WannaCry ransomware pandemic.**

WannaCry infected 200,000+ computers across 150 countries by exploiting the SMBv1 'EternalBlue' vulnerability, encrypting hard drives for Bitcoin ransom.

Q6. Explain the significance of the Stuxnet worm.

Stuxnet was the first cyber weapon to cause physical infrastructure destruction, ruining 1,000+ Iranian nuclear centrifuges via Siemens PLCs.

Q7. What is Business Email Compromise (BEC)?

A social engineering fraud scheme where attackers compromise or spoof executive email accounts to trick financial staff into executing wire transfers.

Q8. How does DNSSEC prevent DNS Cache Poisoning?

By signing DNS resource records with cryptographic keys ('RRSIG'), ensuring clients verify DNS response integrity before caching.

Q9. What are the 7 core principles of GDPR?

Lawfulness, Purpose Limitation, Data Minimization, Accuracy, Storage Limitation, Integrity & Confidentiality, and Accountability.

Q10. What is Data Sovereignty?

The legal requirement that digital data created within a country must be subject to that nation's laws and stored within its physical boundaries.

Q11. Define Malvertising.

Injecting malicious advertisements into legitimate ad networks to infect users via silent drive-by downloads without clicking.

Q12. What is the role of ICANN in internet governance?

Managing global IP address allocation (IPv4/IPv6 via IANA), coordinating DNS root zone servers, and managing top-level domain (TLD) registries.

Q13. Differentiate between Cyber Espionage and Cyber Sabotage.

Cyber Espionage focuses on secret intelligence gathering; Cyber Sabotage focuses on physical or operational system destruction.

Q14. Explain the term 'Drive-by Download'.

Malware installation that occurs automatically upon visiting a compromised website without explicit user download consent.

Q15. What is the GDPR breach notification timeframe?

Data controllers must notify relevant data protection authorities within 72 hours of becoming aware of a personal data breach.

Summary Comparison: Email Authentication Protocols

Protocol	Verification Mechanism	DNS Record Type	Primary Defense Focus
SPF	Validates Sending Mail Server IP	TXT ('v=spf1')	Sender Address Spoofing
DKIM	Validates Cryptographic RSA Header	TXT ('selector._domainkey')	Message Header Tampering
DMARC	Enforces Policy Alignment ('p=reject')	TXT ('_dmarc')	Phishing & Unauthenticated Delivery